

Access Control Policy

SIMULATED / FICTIONAL EVIDENCE — FOR EDUCATIONAL USE ONLY

Organization	CloudFlow Technologies (fictional SaaS vendor)
Product in scope	CloudFlow CRM
Classification	Confidential — Internal Use / Simulated Evidence
Approval status	Approved for simulation (not a live corporate record)
Document owner	Jordan Hale, Chief Information Security Officer
Document ID	POL-AC-002
Version	2.1
Effective date	01 March 2025
Last review date	15 January 2026
Next review	15 January 2027

1. Purpose

This policy defines identity and access management for CloudFlow CRM, corporate identity, and AWS. The objective is least privilege, unique identification, and protection of privileged access.

2. Role-based access control

Access is granted by role, not individual standing entitlements, wherever the platform supports it. Application roles include Tenant Admin, Sales User, Support Agent, and CloudFlow Operator. AWS access uses permission sets. Production data access by CloudFlow personnel requires a documented support ticket except for automated platform operations.

3. Multi-factor authentication

MFA is mandatory for: (a) corporate SSO; (b) CloudFlow CRM privileged (operator) access; (c) AWS IAM privileged roles. Hardware keys are preferred for administrators; TOTP is permitted. Customer tenant users may enable MFA; Nexus should require MFA for its own users via tenant policy.

4. Privileged access

AWS privileged sessions are conducted through a jump host with time-bound roles. Standing administrator rights on laptops are prohibited for production cloud administration.

5. Joiner / mover / leaver

- Joiners: access provisioned from HR-approved role templates after identity proofing.
- Movers: access recertified within five business days of role change.
- Leavers: all access revoked within 24 hours of HR notification; privileged access revoked immediately where feasible.

6. Periodic access reviews

Privileged access is reviewed quarterly. Standard user access is reviewed semi-annually. Reviews are recorded and exceptions tracked.

6.4 Legacy systems exception (disclosed)

A small set of legacy internal administrative utilities used for historical reporting do not support MFA. Access to those utilities requires corporate VPN and password authentication. This exception is recorded and is scheduled for retirement or identity-proxy enforcement. Production CloudFlow CRM and AWS privileged paths are not in this exception set. An assessor should treat this as a partial MFA coverage gap.